JOB-MARKET FOCUS GUIDE

Chapter 12 — Introduction to Security Assessments

Core Concepts, Vulnerability Management, and Practical Hands-On Labs

1. CRITICAL SECURITY CONCEPTS

Understanding security objectives, threat models, and risk evaluation forms the bedrock of SOC analysis, vulnerability assessment, and penetration testing.

Confidentiality

Prevents unauthorized access to sensitive information.

Example: SQL injection exposing customer records or credentials.

Integrity

Prevents unauthorized or accidental modification of data.

Example: An attacker modifying banking details or audit logs.

Availability

Ensures systems and services remain accessible when required.

Example: DoS attack knocking down an e-commerce platform.

1.2 CORE SECURITY DEFINITIONS

Concept	Definition	Practical Example
Threat	Any entity or event capable of causing operational or security harm.	External malicious actor, rogue employee, malware.
Vulnerability	A security flaw or weakness in software, hardware, or process.	Unpatched operating system, misconfigured permission.
Risk	The probability and operational impact of a threat exploiting a weakness.	An attacker exploiting an unpatched server to steal PII.
Control	A safeguard implemented to reduce risk or mitigate threats.	Patch management, MFA, network segmentation, EDR.

1.3 VULNERABILITY VS. EXPLOIT & MITIGATIONS

Vulnerability vs. Exploit

A **Vulnerability** is the dormant flaw (e.g., buffer overflow bug). An **Exploit** is the specific code or vector used to leverage that flaw for unauthorized access or disruption.

Exploit Mitigations

- **ASLR:** Randomizes memory layout locations to hinder memory-based exploits.
- **DEP / NX:** Prevents code execution from non-executable memory segments.

2. TYPES OF SECURITY ASSESSMENTS

Assessment Type	Main Objective	Typical Operational Focus
Vulnerability Assessment	Identify and catalog potential security weaknesses.	Automated scanning, service enumeration, patch audit.
Compliance Assessment	Verify adherence to regulatory/industry standards.	PCI DSS, DISA STIG, FISMA, HIPAA audits.
Penetration Testing	Evaluate exploitability and chain flaws safely.	Recon, exploitation within scope, proof-of-concept.
Application Assessment	Analyze application code and logic security posture.	Web APIs, desktop/mobile app static/dynamic testing.

Testing Methodologies
Black Box: Assessor has zero prior knowledge; simulates external attacker.
White Box: Full access including architecture and source code; comprehensive evaluation.
Hybrid (Gray Box): Partial knowledge provided (e.g., standard user credentials).

3. VULNERABILITY SCANNING & RISK EVALUATION

Scanners compare target signatures, banners, and responses against database definitions (CVEs). Output interpretation is a vital skill.

True Positive
Scanner reports a vulnerability that **actually exists** on the target.

False Positive
Scanner reports a vulnerability that **does not exist** (incorrect alert).

True Negative
Scanner correctly identifies that **no vulnerability exists**.

False Negative
Scanner **fails to detect** a real vulnerability present on system.

3.2 SCANNING CONSIDERATIONS & STANDARDS

- **Authenticated vs. Unauthenticated:** Authenticated scans utilize credentials to inspect local registry, patch levels, and installed packages, uncovering internal flaws invisible to network-only scans.
- **CVE & CVSS:** Common Vulnerabilities and Exposures provides standard IDs. Common Vulnerability Scoring System yields base severity (0.0–10.0).
- **Contextual Risk Rating:** CVSS scores do not equal business risk. Risk must be evaluated using environmental factors (e.g., NIST SP 800-30 framework). A high CVSS bug on an isolated lab machine carries lower risk than on a core production server.
- **Scan Threads & Impact:** Higher threads speed up execution but increase CPU, network bandwidth, and target service load, risking accidental DoS.

4. ASSESSMENT AUTHORIZATION & RULES OF ENGAGEMENT

CRITICAL PROFESSIONAL REQUIREMENT

Never perform testing without explicit, written authorization. Scope verification is mandatory—organizations often misidentify IP spaces or hosting assets. Testing unapproved third-party cloud assets leads to severe legal consequences.

5. COMMON ATTACK VECTORS & IMPACT

Attack Category	Attack Mechanism	Impact & Target
Denial of Service (DoS)	Flooding or resource exhaustion to disrupt operations.	Availability loss across services.
Memory Corruption	Buffer overflows, heap misuse, format string bugs.	System crashes or remote code execution.
SQL Injection (SQLi)	Injecting malicious queries into backend database handlers.	Confidentiality breach, data alteration.
Cross-Site Scripting (XSS)	Executing arbitrary client-side scripts in user sessions.	Session hijacking, credential theft.
Password Attacks	Online (live service interaction) vs. Offline (hash cracking).	Account takeover or lockout.
Client-Side Attacks	Targeting user browser, office software, or phishing.	Initial endpoint compromise.

6. PENETRATION TESTING WORKFLOW

01
Scope & Authorization
Define targets, boundaries, timelines, and obtain legal sign-off.

02
Information Gathering
OSINT, DNS reconnaissance, subdomains, passive discovery.

03
Vulnerability Discovery
Active scanning, service enumeration, banner grabbing.

04
Validation & Exploitation
Confirm real vulnerabilities safely; PoC execution.

05
Post-Exploitation
Assess impact, privilege escalation, lateral movement limits.

06
Reporting & Action
Document findings with proof, business risk, and remediations.

7. PRACTICAL LAB — SECURITY ASSESSMENT FUNDAMENTALS

Perform these non-destructive reconnaissance and posture evaluation tasks on your local Kali Linux machine.

Lab 1: System Reconnaissance Commands

Task 1: System Identification

```
hostname
uname -a
ip -brief address
```

Task 2: Service & Port Audit

```
sudo ss -tulpen
```

Analyze listening addresses (127.0.0.1 vs 0.0.0.0) and associated PIDs.

Task 3 & 4: Patching & Logs Audit

```
sudo apt update && apt list --upgradable
journalctl -b -n 30 --no-pager
```

LAB 1 ANALYSIS FRAMEWORK

Evaluation Questions for Each Task:

1. What precise details were observed in the command output?
2. Does this indicate normal behavior, a service exposure, or a vulnerability?
3. Which CIA Triad leg would be impacted if exploited?
4. What further evidence is required before validating a true issue?
5. What specific remediation or hardening step is recommended?

LAB 2: KNOWLEDGE CHECK SUMMARY

Scan Classification

• Scanner flags missing patch that is applied → **False Positive**
• Real bug missed by scanner → **False Negative**
• Authenticated scan → Deep system visibility.

Scope & Authorization

• Unauthorized target IP range found → **Halt, validate ownership & authorization** before proceeding.